

تقرير قرار الجاهزية

مجتمع السيطرة

مجتمع مهني عربي آمن — بوابة تأكيد البريد وهرمية المالك والمدير

مراجعة ما قبل فتح التسجيل العام

NO-GO

البنية جاهزة للاختبار المحدود؛ ليس لفتح التسجيل العام

المالك والبوابة منشوران ومتحقق منهما؛ لكن البريد الحي، جلسات المالك والمدير، وعزل حسابين حقيقيين ووظيفة تنظيف الوثائق لم تُختبر بعد.

4 أكتوبر 2026 · مراجعة إنتاج بعد نشر بوابة المالك

القرار مبني على فحوص قراءة إنتاجية، رفض طلبات غير مصرح بها، واختبارات محلية معزولة؛ لا على دورة مستخدم مكتملة.

1 الخلاصة التنفيذية

طُبِّقَت بوابة تأكيد البريد ثم الاعتماد، وأضيف دور مالك واحد محفوظ في قاعدة البيانات وواجهات RPC محمية. عُيِّن المالك الأول بعد تأكيد البريد، وأوقف التسجيل العام في Supabase وفي بناء الموقع. نُشِرَت بوابة /owner/ وأُصلِح مسار التوليد الثابت حتى لا يعيد GitHub Pages صفحة 404.

الحكم: NO-GO لفتح التسجيل العام. السبب: لم تكتمل اختبارات البريد الفعلية، وجلسة المالك والمدير، وعزل البيانات بين حسابين حقيقيين، وwebhook التنظيف. إبقاء التسجيل العام مغلقاً هو الإجراء الآمن.

المجال	الحالة	الدليل وحده
المالك	مهيأ حياً	مالك واحد مرتبط بحساب مؤكد؛ لم يُختبر دخوله إلى اللوحة بجلسة فعلية.
الأدوار	مشددة	كتابة user_roles المباشرة مرفوضة؛ وظائف المالك لا تُتاح للمدير.
تأكيد البريد	مطلوب	Confirm email مفعل؛ لم تصل رسالة تأكيد أو استعادة ضمن اختبار حي.
التسجيل العام	مغلق	إعداد Supabase مغلق؛ صفحة التسجيل الحية تعرض «الدخول بالدعوة فقط».
بوابة /owner/	منشورة	الزائر غير المسجل يُحوَّل إلى /login/؛ الصفحة الخاصة noindex.
عزل A عن B	غير مختبر	لا توجد جلسات JWT حقيقية منفصلة لاختبار الرسائل والوثائق وطلبات التوثيق.
Edge / التنظيف	جزئي	الوظائف نشطة ورفضت طلباً بلا اعتماد؛ سر التنظيف Database Webhook غير متحققين.

2 حدّ مهم في صلاحية المدير

المالك وحده يعيّن أو يسحب أدوار الموظفين العامة مثل manager وmoderator وcoach عبر RPC المالك. أمّا المدير فيمكنه، ضمن مسار مراجعة طلب توثيق محدد، اعتماد حالة verified؛ هذا ليس إسناداً عاماً لدور إداري. لم يُختبر هذا المسار بجلسة JWT إنتاجية.

3 أدلة الإنتاج والنشر

3.1 قاعدة البيانات والهوية

سُجلت migrations بوابة الاعتماد وتضييق صلاحيات anon، ثم هرمية المالك platform_owner_hierarchy بالإصدار 20261004000220. أظهر التحقق قراءة فقط في الإنتاج: مالك واحد، وحساب آخر حالته pending؛ لم تُدرج عناوين بريد أو معرفات. لم يُعد تشغيل setup.sql على المشروع القائم.

أزال التغيير سياسة Managers administer roles القديمة، وأكد الاستعلام الحي غياب صلاحيات INSERT/UPDATE/ DELETE المباشرة عن authenticated على public.user_roles. كما لم تعد policy القديمة موجودة. جداول المالك وسجل تدقيقه لا تُقرأ مباشرة من العميل، وعمليات الدور والإعداد والتعليق تمر عبر فحوص مالك على الخادم.

3.2 إعداد Auth والموقع

أعيد تحميل صفحة إعداد Supabase للتحقق من بقاء Confirm email مفعلاً و Allow new users to sign up مغلقاً. يعرض الموقع فعلياً دعوة فقط. المتصفح المعزول فتح /owner/ ثم أعاد الزائر إلى /login/، وعرض /register/ رسالة توقف التسجيل؛ لم يسجل Console أخطاء. استجابات الصفحة الرئيسية وواجهات الدخول والتسجيل والمالك بـ HTTP 200، وحُمل CSS و JavaScript للمالك بـ 200. ملف المالك ثابت وخاص بـ noindex, nofollow.

نجح workflow التطبيق [37164428472] ونشر [37164428191] Pages بعد الإصلاح النهائي للمسار، على commit f2d8ee4. لم يُدخل أي مفتاح إداري إلى متصفح المستخدم؛ الحزمة تستخدم إعدادات Supabase العامة فقط.

3.3 الوظائف والاستشارات الأمنية

(v1) owner-invite و (v2) delete-account و (v1) cleanup-verification-files أنشطة. دعوة المالك والحذف يتطلبان JWT، والتنظيف يفرض x-cleanup-secret مع verify_jwt=false. أعاد POST بلا JWT إلى الدعوة والحذف 401 دون إرسال بريد أو حذف حساب. لم يُجر تنفيذ مصادق، ولم يُتحقق من السر البعيد أو webhook التنظيف.

أظهر Supabase Security Advisor ثلاث ملاحظات INFO عن جداول داخلية عليها RLS بلا سياسات، وتحذيراً لـ is_staff المتاحة لـ anon، و 18 تحذيراً لدوال SECURITY DEFINER المتاحة لـ authenticated، وتحذيراً بأن حماية كلمات المرور المسربة غير مفعلة. لم يُختبر كل RPC بجلسة JWT حية؛ يجب مراجعة هذه النقاط وتفعيل حماية كلمات المرور المسربة إن كانت متاحة قبل أي فتح عام.

3.4 الاختبارات المحلية

نجح npm run typecheck و npm run lint و npm run build، وأثبت البناء وجود shell خاص للمالك. نجح platform_owner_smoke.sql في قاعدة PostgreSQL مؤقتة: bootstrap، عمليات RPC للمالك، رفض المدير لمسارات المالك، ومنع الكتابة المباشرة وإقرار الحساب المعلق لنفسه. كما نجح account_approval_smoke.sql المحلي. هذه اختبارات claims اصطناعية ومعاملات معزولة تنتهي بـ ROLLBACK، وليست اختبارات REST/JWT على قاعدة الإنتاج.

4 البوابات المتبقية قبل READY

1. سجّل دخول المالك يدوياً بعد استخدام استعادة كلمة المرور إذا لزم، وافتح [بوابة المالك]. تحقق من دعوة حساب اختبار، عرض سجل التدقيق، والتعليق/الاستعادة دون استخدام بيانات حقيقية.
2. أنشئ مديراً وحسابي اختبار A و B عبر الدعوة. اختبر التأكيد وإعادة إرسال الرسالة واستعادة كلمة المرور، وتأكد من بقاء الحساب المدعو pending حتى الموافقة.
3. اختبر بجلسات JWT منفصلة وطلبات الموقع/API أن A لا يقرأ رسائل أو طلبات توثيق أو ملفات B، ولا يغير دوره أو حالة اعتماده؛ واختبر منع العضو من النشر العام وحد الرسائل اليومي.
4. اختبر حد المدير عملياً: لا يعيّن أدوار الموظفين ولا يقرأ بيانات المالك؛ ويمكنه فقط معالجة طلب توثيق محدد وفق الصلاحية. سجّل النتيجة دون الخلط بين verified ودور إداري.
5. اضبط SMTP موثوقاً وأثبت وصول رسائل التأكيد والاستعادة فعلياً. راجع تحذير كلمات المرور المسربة وفَعْلَه إن كان متاحاً في الخطة.
6. أضف CLEANUP_WEBHOOK_SECRET من لوحة Supabase وأنشئ Database Webhook على public.verification_requests مع header x-cleanup-secret؛ اختبره بمرفق اصطناعي فقط.
7. اختبر delete-account بحساب تطوير مؤقت وفارغ، ثم تحقق من تنظيف ملفه؛ لا تستخدم حساب المالك ولا تحذف بيانات حقيقية.

قرار الإطلاق: NO-GO حتى اجتياز البوابات أعلاه وتوثيق نتائجها.

لا يُفتح التسجيل العام اعتماداً على نجاح البناء أو وجود مالك فقط؛ يلزم إثبات البريد، الصلاحيات الحية، عزل حسابين، ووظائف التنظيف والحذف.

5 تنبيه أمني

كلمة مرور ظهرت سابقاً في نص المحادثة وتُعامل على أنها مكشوفة؛ لا تُستخدم مجدداً. غيّر لها لدى مزود البريد، وغيّر كلمة مرور حساب الموقع إن كانت نفسها، من خلال مسار الاستعادة الرسمي. لم تُدرج في هذا التقرير أي كلمة مرور أو مفتاح أو بريد.

الموقع: [الصفحة العامة] · [بوابة المالك] · المراجع التشغيلية: [التدقيق الأمني] و [دليل الإعداد]. تاريخ الفحص: 4 أكتوبر 2026.